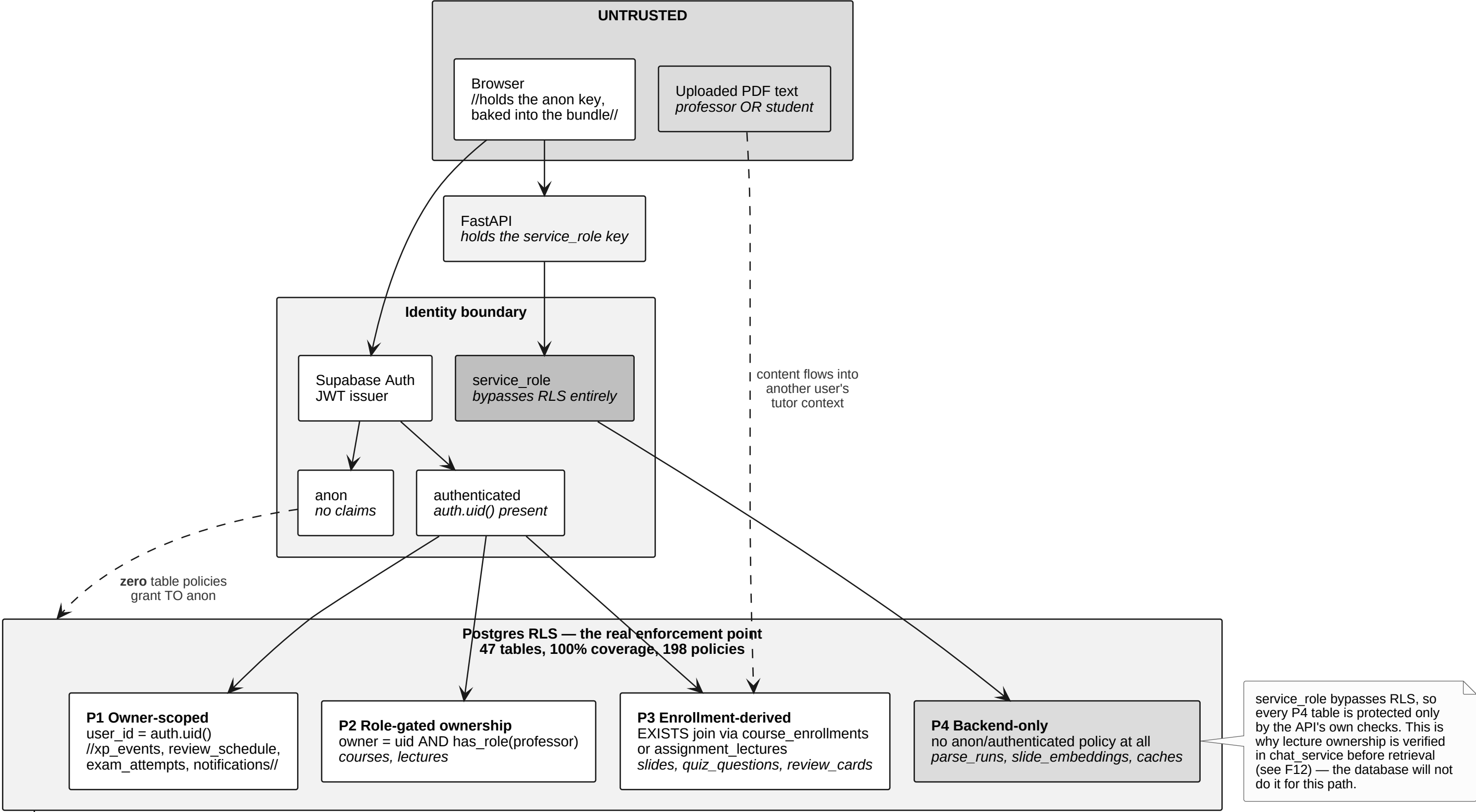


Trust boundaries — where authorisation is actually enforced

Please use CSS style instead of skinparam padding



The structural hazard. Postgres OR-combines permissive SELECT policies, so effective visibility is the UNION of every applicable policy — not the intersection. Called out explicitly in migration 20260719020000:25-29.

And it is untested end to end: no test composes a real endpoint against real RLS (MILESTONE_2026_08.md:205-210), so the union behaviour that caused the original cross-tenant leak remains unguarded at the integration level.

Authorisation lives in the database. The API layer adds ownership checks on top for service_role paths, but is not the boundary. See F15 for how these policies were hardened across five migrations, and F4 for why uploaded content is untrusted.